ICS/OT/IoT Threat Model

Rockwell Automation Allen-Bradley ControlLogix 5580 PLC (1756-L81E/L82E/L83E/L84E/L85E), firmware v28-v30+, manual 1756-UM543E-EN-P

Generated 2026-08-09 03:31:26 UTC - Model: anthropic / claude-opus-4-8

> Frameworks: MITRE EMB3D - MITRE ATT&CK for ICS - ISA/IEC 62443 (3-3, 4-2, 4-1, 2-1) - ISA-TR84.00.09 - Attify IoT.
> Identifiers marked * are model-supplied (not from the embedded reference set).

Executive Summary

The ControlLogix 5580 is a high-performance Logix5000 controller with a dual-core architecture (separate control and communications cores), an embedded 10/100/1000 Mbps dual-port EtherNet/IP interface, a USB 2.0 Type-B port, a removable Secure Digital (1784-SD1/SD2) card, a 1756 DDR backplane, a physical RUN/REM/PROG mode keyswitch and a reset button (Stage 1/Stage 2). It speaks CIP over EtherNet/IP, and via 1756 comm modules bridges to ControlNet, DeviceNet, DH+/Universal Remote I/O, FOUNDATION Fieldbus, HART, Modbus and raw socket protocols, and serves diagnostic web pages over HTTP and CIP Sync/PTP time. The dominant risk is that CIP/EtherNet/IP management functions (program download T0843, mode change T0858, firmware update T0800/T0857, MSG/GSV-SSV) historically lack strong message authentication and encryption (TID-406/TID-408/TID-4111/TID-4112); the manual documents no user identity/credential or transport cryptography on the controller itself, relying instead on the physical keyswitch, Electronic Keying, Source Protection and offboard FactoryTalk Security. Firmware integrity is enforced by a signing certificate ("Corrupt Certificate Received"/"Corrupt Image Received" faults), but boot fallback to firmware 1.xxx and SD-card auto-load-on-powerup create rollback (TID-216) and untrusted-external-storage (TID-111) exposure, and remotely initiated ControlFLASH/AutoFlash updates enable DoS (TID-217). Unauthenticated web pages, PTP grandmaster disclosure, BOOTP/DHCP identity exposure and duplicate-IP conflict mode widen the attack and reconnaissance surface. Because L8xE controllers can co-reside with 1756-L8xES/Logix5585 safety partners and BPCS logic, cyber manipulation of control tasking or I/O can create a demand while defeating independent protection layers, so ISA-TR84.00.09 hazard scenarios are in scope. Recommended emphasis: keyswitch in RUN with key removed, disable Ethernet port/web pages/status display via CIP hardening, lock SD card, enforce FactoryTalk Security and CIP Security (DTLS/TLS) where supported, and segment the controller into a dedicated 62443 zone with default-deny conduits.

1. System Model

ControlLogix 5580 controller resides in a 1756 chassis on a DDR backplane alongside I/O and communication modules. It exposes an embedded dual-port EtherNet/IP interface (CIP), a USB 2.0 Type-B port for local programming/firmware, an SD card slot for project/firmware load-store, a physical mode keyswitch and reset button. Studio 5000 Logix Designer / RSLinx engineering workstations connect over EtherNet/IP or USB to download programs, change mode, and flash firmware. The controller bridges via 1756 comm modules to ControlNet, DeviceNet, DH+/RIO, FOUNDATION Fieldbus and HART field networks, produces/consumes interlock tags with peer controllers, serves HTTP diagnostic web pages, and synchronizes time via CIP Sync/PTP.

Components

Component	Role	Sub-components
Logix5585 CPU / dual-core SoC	Executes user control logic (control core) and network/comms stack (communications core)	Control processor core, Communications processor core, On-chip cache/RAM, Firmware security certificate validation logic
DDR DRAM (PID-1241)	Runtime user memory / project execution	DDR SDRAM chips, Memory controller
Nonvolatile memory (NVS)	Stores Ethernet port hardening settings, config, boot firmware	Boot firmware 1.xxx, NVS flash
Energy Storage Module (1756-N2/N2XT ESM)	Backs up program to on-board storage on power-down	Capacitor energy store, Embedded storage circuit
Embedded EtherNet/IP interface	Dual-port 10/100/1000 RJ45 EtherNet/IP + CIP + HTTP web + PTP	Dual RJ45 PHYs, TCP/IP stack, CIP object model, HTTP web server, PTP/CIP Sync grandmaster
USB 2.0 Type-B port	Local programming, config, firmware update (temporary use)	USB-CIP layer, USB OTG (slave/host) controller, Virtual backplane logical address

Component	Role	Sub-components
Secure Digital card (1784-SD1/SD2)	Removable project + firmware image load/store; auto-load on powerup	Flash memory, Lock/unlock tab, Load Image config
1756 DDR backplane	Chassis interconnect to I/O and comm modules	DDR backplane bus, Electronic Keying enforcement
Mode keyswitch + reset button	Physical operating-mode and reset control (RUN/REM/PROG, Stage1/Stage2)	3-position keyswitch, Reset button
Comm/I-O modules	Field network bridging and I/O	1756-EN2T/EN2TR/EN3TR/EWEB EtherNet/IP, 1756-CN2/CN2R ControlNet, 1756-DNB DeviceNet, 1756-DHRIO DH+/RIO, 1788-EN2FFR/CN2FFR FF, 1756-IF8H/IF16IH HART, Safety partner 1756-L8xES/Logix5585 (if configured)

Interfaces

Interface	Type	Protocol	Exposure
Embedded EtherNet/IP (dual-port)	network	EtherNet/IP / CIP (TCP 44818, UDP 2222), HTTP web pages, PTP/CIP Sync (UDP 319/320), SMTP, DNS, BOOTP/DHCP	zone
USB 2.0 Type-B	physical	USB-CIP (RSLinx driver)	physical
SD card slot	physical	SD flash / project+firmware image load	physical
1756 DDR backplane	bus	CIP over DDR backplane	internal
Mode keyswitch / reset button	physical	Mechanical RUN/REM/PROG, Stage1/Stage2 reset	physical
ControlNet	network	CIP over ControlNet (scheduled/unscheduled)	zone
DeviceNet	network	CIP over CAN	zone
DH+ / Universal Remote I/O	network	DH+ / RIO (57.6/115.2/230.4 Kbps)	zone
HART / FOUNDATION Fieldbus (via I/O modules)	bus	HART master, FF H1/HSE	zone
Socket interface	api	Raw TCP/UDP sockets via Socket Object + MSG	zone

Data Flows

From	To	Data	Protocol	Crosses boundary
Engineering Workstation (Studio 5000/RSLinx)	Controller embedded EtherNet/IP	Program download/upload, mode change, tag read/write, firmware (ControlFLASH/AutoFlash)	EtherNet/IP / CIP	Yes
Engineering Workstation	Controller USB port	Local programming, IP config, firmware update	USB-CIP	Yes
SD card	Controller CPU	Project + firmware image auto-load on powerup	SD flash / Load Image	Yes
Controller	Peer controllers	Produced/consumed interlock tags, MSG instructions	CIP over EtherNet/IP/ControlNet	Yes
Controller	I/O & field devices	I/O image, HART/FF process values, motion (CIP Motion)	CIP / HART / FF / RIO	Yes
Web browser	Controller HTTP web pages	Diagnostics, tasks/CPU, browse chassis, TCP/IP & PTP status	HTTP (unauthenticated)	Yes
BOOTP/DHCP server	Controller	IP assignment, MAC exposure	BOOTP/DHCP	Yes

2. Device Model - EMB3D Properties

Property	Category	Feature / Interface	Present	Notes
PID-11	Hardware	Dual-core Logix5585 microprocessor (control + comms cores)	Yes	Separate control and communications cores with CPU utilization gauges; dual-core SoC.
PID-12	Hardware	External memory/storage (NVS, SD card, DDR)	Yes	NVS nonvolatile memory, removable SD card, DDR DRAM external to CPU.
PID-123	Hardware	Removable Secure Digital card + boot ROM	Yes	1784-SD1/SD2 stores project + firmware image; boot firmware 1.xxx in ROM/NVS.
PID-1241	Hardware	DDR DRAM	Yes	Double Data Rate memory referenced for runtime and backplane.
PID-14	Hardware	USB 2.0 Type-B external peripheral interconnect	Yes	USB-CIP, OTG slave/host, virtual backplane logical address; temporary local access.
PID-15	Hardware	Hardware access / debug port (assumed JTAG/UART on SoC)	Yes	Not documented in manual; assumed present on SoC/board for production/debug.
PID-21	System Software	Bootloader / boot firmware 1.xxx	Yes	Boot firmware fallback on interrupted update; requires firmware install.
PID-25	System Software	Firmware security certificate (root of trust)	Yes	'Corrupt Certificate Received' fault implies signing/cert validation; RoT immutability not documented.
PID-27	System Software	Firmware/software update support (ControlFLASH, AutoFlash, SD)	Yes	Multiple update paths over EtherNet/IP, USB, or SD auto-load.
PID-272	System Software	Cryptographic firmware integrity mechanism	Yes	Signature Mismatch #0005, Corrupt Image Received integrity checks.
PID-274	System Software	User firmware version selection during update	Yes	ControlFLASH lets operator pick revision; enables rollback.
PID-275	System Software	Remotely-initiated firmware updates	Yes	ControlFLASH/AutoFlash over EtherNet/IP; controller must be in Program/Remote.
PID-28	System Software	System event logging / fault log	Yes	Fault log (GSV MinorFaultBits, FaultLog class); protection/retention not documented.
PID-311	Application Software	HTTP diagnostic web pages	Yes	Diagnostics/Tasks/Browse Chassis/TCP-IP/PTP pages, no authentication noted; can be disabled.
PID-312	Application Software	IEC 61131-3 programming languages / Add-On Instructions	Yes	Ladder/FBD/ST/AOI logic; Source Protection for AOIs.
PID-321	Application Software	Deploy custom programs from Studio 5000 IDE	Yes	Program download over configurable comm path.
PID-323	Application Software	Program executable formats / controller tasking	Yes	Tasks/routines executed by control core; Modify Controller Tasking risk.
PID-331	Application Software	Unauthenticated services (web, CIP, PTP)	Yes	Controller web pages and CIP management reachable without controller-side user auth.
PID-332	Application Software	Authenticated services via FactoryTalk Security (offboard)	Yes	Authorization/authentication delegated to FactoryTalk Security service, not on-device.

Property	Category	Feature / Interface	Present	Notes
PID-41	Networking	Remote network services (EtherNet/IP, HTTP, PTP, SMTP, DNS)	Yes	Multiple exposed network services on embedded Ethernet port.
PID-411	Networking	Remote config/sensitive modification (CIP Set Attribute, GSV/SSV)	Yes	CIP Generic MSG can disable Ethernet port/web/display; GSV/SSV change config at runtime.
PID-4111	Networking	Protocol lacks message authentication (legacy CIP/EtherNet/IP)	Yes	No message auth documented in manual; CIP Security optional/not in excerpt.
PID-4112	Networking	Protocol lacks message encryption (cleartext CIP/HTTP/DH+)	Yes	Cleartext CIP, HTTP web pages, BOOTP, PTP; no transport encryption documented.
PID-42	Networking	Message forwarding/routing (CIP routing, MSG bridging)	Yes	Routes CIP across networks/chassis; DH+ up to 4 networks/3 chassis; socket relay.

3. EMB3D Threat -> Mitigation Table

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
Embedded EtherNet/IP CIP management (program download, mode change, tag write)	TID-406	Unauthorized Messages or Connections	High	High	MID-034, MID-038, MID-083, MID-018	Enable CIP Security (DTLS/TLS) message authentication, enforce FactoryTalk Security, restrict conduits with ACL/firewall, require auth for privileged CIP functions.
CIP / HTTP / DH+ / BOOTP / PTP traffic	TID-408	Unencrypted Sensitive Data Communication	High	Medium	MID-035, MID-081, MID-044	Deploy CIP Security transport encryption, tunnel management traffic, use validated crypto; disable web pages/status display.
EtherNet/IP TCP/IP + CIP stack (communications core)	TID-202	Exploitable System Network Stack Component	Medium	High	MID-008, MID-080, MID-088, MID-004	Robust/decidable parsers, request processing limits, formally verified parsers, memory hardening; keep firmware patched.
EtherNet/IP stack / duplicate-IP conflict / connection manager	TID-405	Network Stack Resource Exhaustion	Medium	High	MID-080, MID-032, MID-083	Rate-limit connections, availability manager for essential functions, network ACLs; monitor NET conflict mode.
ControlFLASH/AutoFlash remote firmware update	TID-217	Remotely Initiated Updates Can Cause DoS	Medium	High	MID-026, MID-031, MID-018	Secure firmware update with physical-presence/keyswitch gating; require authorization; keyswitch in RUN blocks flashing.
Firmware update / ControlFLASH revision selection	TID-216	Firmware Update Rollbacks Allowed	Medium	Medium	MID-030, MID-026, MID-056	Enforce anti-rollback minimum revision, signed updates, allow disabling/locking SD removable storage.
SD card project+firmware auto-load on power-up	TID-111	Untrusted External Storage	Medium	High	MID-056, MID-054, MID-026	Physically control/lock SD slot, authenticate stored images, disable removable storage load where possible.
Boot firmware 1.xxx / firmware security certificate	TID-201	Inadequate Bootloader Protection and Verification	Low	High	MID-002, MID-029, MID-001	Hardware-backed secure boot chain with immutable root of trust and image authentication.

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
Firmware image signing / integrity validation	TID-213	Faulty FW/SW Update Integrity Verification	Low	High	MID-026, MID-027, MID-042	Robust signature verification with validated crypto libraries; verify binary-vs-source consistency.
Unauthenticated HTTP diagnostic web pages	TID-310	Remotely Accessible Unauthenticated Services	High	Medium	MID-016, MID-018, MID-073	Disable web pages (CIP class F5), require auth, apply least functionality.
On-device fault/event log	TID-225	Logs can be manipulated on the device	Medium	Medium	MID-017, MID-085, MID-084	Security-relevant auditing, export logs off-device, restrict sensitive data in logs.
GSV/SSV runtime config + CIP Generic MSG hardening controls	TID-224	Excessive Access via Software Diagnostic Features	Medium	Medium	MID-039, MID-018, MID-012	Restrict diagnostic functions, require authentication for administrative actions, apply access control.
Electronic Keying (Disable Keying option)	TID-406	Unauthorized Messages or Connections	Medium	Medium	MID-070, MID-011, MID-016	Use Exact Match keying, peripheral/component authentication, avoid Disable Keying.
Produce/Consume interlock tags & MSG (rogue master)	TID-407	Missing Message Replay Protection	Medium	High	MID-034, MID-036, MID-037	Authenticate network messages, use nonces and timestamps (CIP Security).
USB 2.0 Type-B / SD physical ports	TID-115	Firmware/Data Extraction via Hardware Interface	Low	Medium	MID-057, MID-058, MID-031	Disable/protect debug ports, engage readout protection, require physical presence.
DDR DRAM / RAM contents	TID-223	System Susceptible to RAM Scraping	Low	Medium	MID-065, MID-053, MID-064	RAM encryption, IOMMU DMA controls, keep critical data on-chip.

4. MITRE ATT&CK for ICS

Tactic	Technique ID	Technique	Applicability	Related EMB3D
Initial Access	T0819	Exploit Public-Facing Application	Internet/DMZ-exposed EtherNet/IP or web pages on the controller reachable directly.	TID-202, TID-310
Initial Access	T0866	Exploitation of Remote Services	Exploit CIP/EtherNet/IP stack (historical Rockwell CVEs) to gain access.	TID-202, TID-405
Initial Access	T0847	Replication Through Removable Media	Malicious SD card or infected project loaded at powerup/on USB.	TID-111
Initial Access	T0864	Transient Cyber Asset	Engineering laptop running Studio 5000/RSLinx moves in and connects over EtherNet/IP or USB.	TID-303
Execution	T0858	Change Operating Mode	If keyswitch in REM, CIP command switches controller to Program/Remote to enable edits.	TID-406, TID-224
Execution	T0821	Modify Controller Tasking	Alter tasks/scan cycle via download to change control behavior.	TID-406
Execution	T0871	Execution through API	CIP Generic MSG / GSV/SSV invoke controller functions and disable hardening.	TID-224, TID-411
Persistence	T0857	System Firmware	Flash malicious controller firmware via ControlFLASH/AutoFlash/SD for persistence.	TID-213, TID-216, TID-111
Persistence	T0873	Project File Infection	Infect Studio 5000 .ACD project file to reintroduce malicious logic on next download.	TID-303, TID-301

Tactic	Technique ID	Technique	Applicability	Related EMB3D
Persistence	T0889	Modify Program	Change ladder/FBD/AOI logic on the controller to persist manipulation.	TID-406, TID-301
Evasion	T0856	Spoof Reporting Message	Falsify produce/consume or CIP reporting to mask manipulation (no replay protection).	TID-407, TID-408
Discovery	T0846	Remote System Discovery	EtherNet/IP List Identity, Browse Chassis web page, BOOTP MAC history enumerate devices.	TID-310, TID-408
Discovery	T0888	Remote System Information Discovery	CIP/web/PTP disclose firmware, hw rev, serial, MAC, tasks/CPU utilization.	TID-310, TID-226
Collection	T0845	Program Upload	Upload controller logic over CIP to clone/analyze process (unless Source Protection).	TID-408, TID-406
Collection	T0861	Point & Tag Identification	Enumerate controller-scoped tags/produced tags to understand process.	TID-408
Lateral Movement	T0843	Program Download	Download modified logic to the controller over EtherNet/IP/USB.	TID-406
Command and Control	T0869	Standard Application Layer Protocol	Blend C2/manipulation into legitimate EtherNet/IP/CIP or socket-interface traffic.	TID-401, TID-412
Inhibit Response Function	T0800	Activate Firmware Update Mode	Trigger ControlFLASH to make controller non-responsive.	TID-217
Inhibit Response Function	T0814	Denial of Service	Stack/resource exhaustion, duplicate-IP conflict, thermal DoS crash controller.	TID-405, TID-202
Inhibit Response Function	T0816	Device Restart/Shutdown	Force restart via CIP or Stage1/Stage2 reset to disrupt control.	TID-224
Impair Process Control	T0836	Modify Parameter	Change setpoints/parameters via CIP tag writes / GSV-SSV.	TID-406, TID-411
Impair Process Control	T0835	Manipulate I/O Image	Force/alter I/O image; forces take effect immediately (FORCE indicator).	TID-406
Impact	T0880	Loss of Safety	If safety partner/BPCS interlocks are defeated, protective function is lost.	TID-406, TID-407
Impact	T0879	Damage to Property	Manipulated control of drives/motion (PowerFlex/Kinetix) damages equipment.	TID-406, TID-835*

5. Attify IoT Reverse-Engineering / Attack Surface

Domain	Vector	Technique	Finding / Hypothesis	Related EMB3D
Hardware	Debug/test interface discovery (UART/JTAG/SWD)	Pin-map SoC/board with logic analyzer/JTAGulator to find latent debug ports	Manual documents no JTAG/UART; assumed present on Logix5585 SoC/board for production/debug (readout risk).	TID-115, TID-119
Hardware	Chip-off / flash & SD extraction	Dump NVS/DDR and SD card image (flashrom/CH341A, SD reader)	SD stores project+firmware image; extraction/modification feasible if physical access to card/slot.	TID-108, TID-111
Hardware	Fault injection / side channel	Voltage/clock glitch to bypass firmware certificate check / secure boot	Firmware cert validation exists; glitch resistance not documented - hypothesis for secure-boot bypass.	TID-105, TID-201
Firmware	Update/boot chain analysis	Analyze ControlFLASH image signing, boot 1.xxx fallback, rollback and SD auto-load	Signature/certificate faults (#0005, Corrupt Image) confirm signing; rollback + SD auto-load are weak points.	TID-201, TID-213, TID-216

Domain	Vector	Technique	Finding / Hypothesis	Related EMB3D
Firmware	Secret & credential hunting	Entropy/grep firmware image for keys, certs, hardcoded creds	No credentials documented; hunt for embedded signing/cert keys and default secrets.	TID-226, TID-328
Network	Service & port enumeration + ICS protocol testing	nmap/EtherNet/IP List Identity, CIP fuzzing, unauthorized command/mode change	Open EtherNet/IP (44818/2222), HTTP, PTP, BOOTP; unauthenticated CIP management accepted.	TID-406, TID-405, TID-401
Network	Cleartext & MitM	Capture CIP/HTTP/BOOTP/PTP, ARP redirect, replay produce/consume tags	Traffic is cleartext with no documented message auth/replay protection; rogue-master feasible.	TID-408, TID-407
Network	Socket interface / routing abuse	Abuse Socket Object + MSG raw sockets and CIP routing to pivot/tunnel	Up to 32 sockets/module and CIP cross-network routing enable pivoting and covert channels.	TID-412, TID-401
Application	Embedded/management web UI review	Access controller web pages for auth bypass / info disclosure	Web pages served without authentication expose diagnostics, tasks, chassis, TCP/IP & PTP data.	TID-310, TID-319
Application	Engineering software trust abuse	Compromise Studio 5000/RSLinx workstation or .ACD project to push logic/firmware	Controller over-trusts offboard IDE; FactoryTalk Security is external and can be bypassed if WS is owned.	TID-303, TID-301

6. ISA/IEC 62443 Requirements Mapping

6.1 62443-4-2 Component Requirements

Req ID	Name	Design Mitigation	Addresses
CR 1.1 / CR 1.2	Human user & software/device identification and authentication	Controller relies on offboard FactoryTalk Security for human auth and has no per-interface device auth on legacy CIP; adopt CIP Security device authentication and enforce identity on all interfaces incl. USB.	TID-406, TID-310
CR 1.5	Authenticator management	No hardcoded/default credentials; manage FactoryTalk/CIP Security authenticators and rotate keys/certs; protect firmware signing private keys.	TID-328, TID-311
CR 2.1	Authorization enforcement (RBAC least privilege)	Enforce role-based authorization for program download, mode change, firmware update, tag write, GSV/SSV via FactoryTalk Security; keyswitch RUN as compensating control.	TID-406, TID-224
CR 2.13 / EDR 2.13	Use of physical diagnostic and test interfaces	Protect/disable USB, SD auto-load, and any JTAG/UART; require physical presence (keyswitch) for privileged local actions.	TID-115, TID-111
CR 3.1	Communication integrity	Enable CIP Security (message authentication) to protect CIP/produce-consume from tamper and rogue master.	TID-406, TID-407
CR 3.4 / EDR 3.14	Software/information integrity & boot integrity	Signed firmware (cert validation, Signature Mismatch #0005) plus hardware root of trust and secure boot; verify project integrity.	TID-201, TID-213
CR 3.5	Input validation	Harden EtherNet/IP/CIP parsers against malformed packets; apply request limits to prevent stack exploitation/exhaustion.	TID-202, TID-405
EDR 3.10 / CR 3.10	Support for updates	Authenticated, integrity-verified, anti-rollback firmware update; gate remote flashing with authorization and physical presence.	TID-216, TID-217, TID-213

Req ID	Name	Design Mitigation	Addresses
EDR 3.11	Physical tamper resistance and detection	Detect SD/USB/keyswitch tamper; secure chassis and readout protection for memory.	TID-111, TID-115
CR 3.9 / CR 6.1	Protection of audit information / log accessibility	Protect fault/audit log from tampering and export off-device to a SIEM/historian.	TID-225, TID-226
CR 4.1 / CR 4.3	Information confidentiality & use of cryptography	Encrypt management traffic (CIP Security/TLS) and protect signing keys with validated crypto; Source Protection for AOIs.	TID-408, TID-317
CR 7.1 / CR 7.2	Denial of service protection & resource management	Preserve control-core essential functions under CIP flood/duplicate-IP/socket exhaustion; separate comms core helps isolate.	TID-405, TID-217
CR 7.7	Least functionality	Disable Ethernet port, web pages, and status display via CIP hardening; avoid Disable Keying; disable unused field networks.	TID-310, TID-224

6.2 62443-3-3 System Requirements

Req ID	Name	System Control
SR 1.1	Human user identification and authentication	Deploy FactoryTalk Security domain to authenticate all engineers accessing the controller from Studio 5000/RSLinx.
SR 1.2	Software process and device identification and authentication	Use CIP Security to authenticate engineering stations and peer controllers on conduits to the controller.
SR 2.1	Authorization enforcement	Enforce least-privilege roles for download/mode/firmware operations across the control system.
SR 3.1	Communication integrity	Protect CIP conduits with integrity mechanisms (CIP Security) between EWS, controllers, and I/O.
SR 3.4	Software and information integrity	Monitor for unauthorized program/firmware changes; use signed images and change detection.
SR 5.1 / SR 5.2	Network segmentation & zone boundary protection	Place controller in a dedicated control zone; deny-by-default conduits via Stratix/firewall; block Internet exposure.
SR 6.2	Continuous monitoring	Monitor EtherNet/IP for List Identity scans, mode changes, downloads, firmware updates, duplicate-IP events.
SR 7.1	Denial of service protection	Protect essential control functions from CIP DoS via segmentation, rate limiting and IDS.
SR 7.6 / SR 7.7	Security configuration settings & least functionality	Standardize hardened baseline: keyswitch RUN, disabled web/port/display, Exact Match keying, locked SD.

6.3 62443-4-1 Secure Development Lifecycle

Practice	Name	Recommendation
SR-2	Product threat model	Maintain a per-release threat model of CIP/EtherNet/IP, USB, SD and firmware update paths for the 5580.
SD-4	Secure by design	Default-deny management interfaces, attack-surface reduction (web/port off by default), on-device authentication rather than sole reliance on offboard FactoryTalk.
SI-2	Secure implementation / coding	Apply memory-safe coding and hardened CIP/TCP parsers on the communications core.
SVV-3	Vulnerability & fuzz testing	Fuzz EtherNet/IP, CIP, HTTP, PTP and USB-CIP interfaces; regression-test firmware certificate validation and rollback logic.
DM-1	Management of security-related issues	Maintain PSIRT intake and publish advisories/CVEs for CIP/EtherNet/IP and firmware issues.
SUM-1	Security update management	Provide signed, anti-rollback firmware and clear update guidance; align firmware/Studio major versions securely.

Practice	Name	Recommendation
SG-3	Security guidelines	Publish hardening guide (keyswitch, disable web/port/display, CIP Security, SD/USB control) - as in Appendix B.
SM-9	SBOM / third-party component management	Maintain SBOM for network stack and OSS in firmware; map to CVEs for the L8xE line.

7. ISA-TR84.00.09 Safety / Hazard / Consequence

Applicable: Yes - SIS/SIF: The ControlLogix 5580 (L8xE) is a BPCS controller, not itself the safety logic solver; however it can co-reside in the 1756 chassis with a GuardLogix/Logix5585 Safety Partner (1756-L8xES, referenced 'SAFETY ON') and it drives interlocks, produce/consume safety-adjacent tags, and final elements (PowerFlex/Kinetix drives) that participate in protection layers. Per ISA-TR84.00.09, cyber manipulation of the BPCS controller can create a demand on a SIF while simultaneously defeating independent protection layers (BPCS interlocks, alarms). SIF example: high-pressure/temperature trip that brings the process to a safe state; its SIL claim can be invalidated by cyber events on shared conduits or the shared chassis backplane if BPCS/SIS independence (TR84-INDEP) is not preserved.

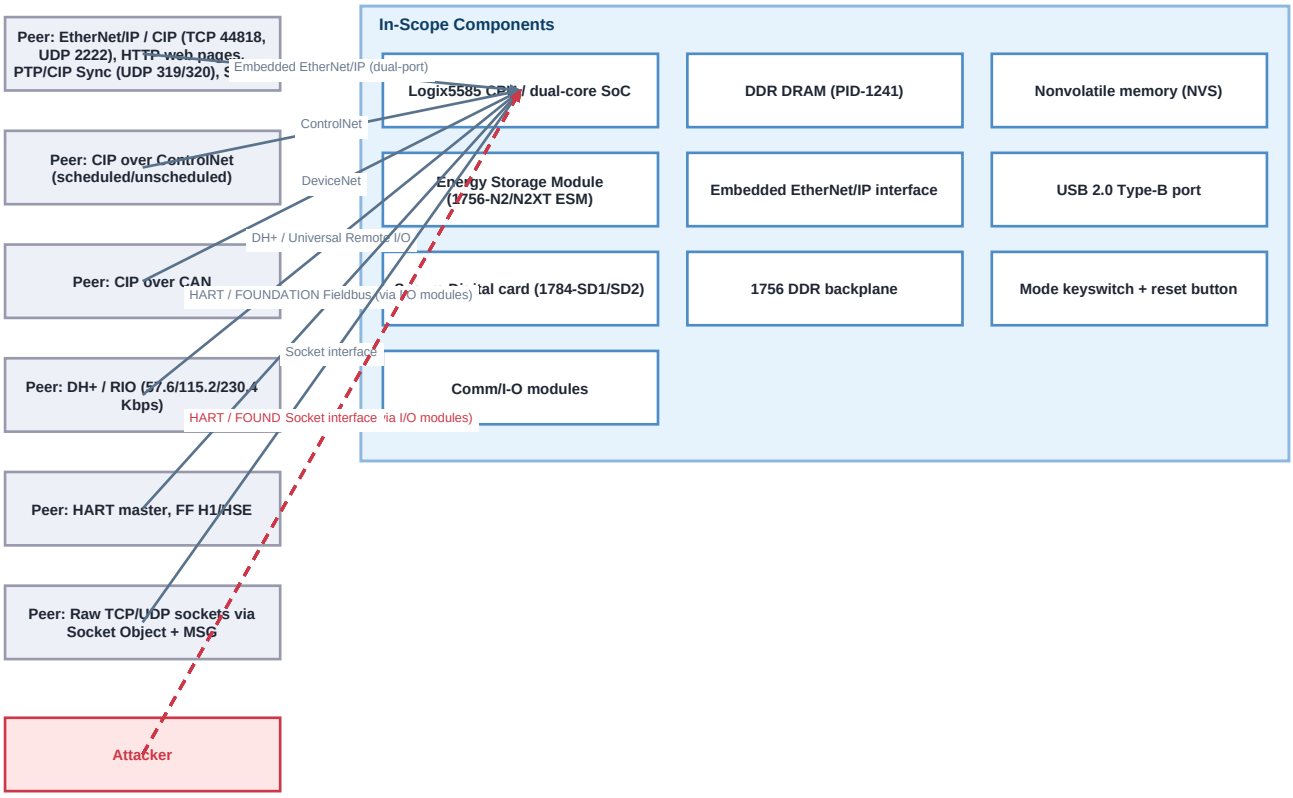
Scenario	Attack Path	Consequence	Severity	Defeats IPLs	Countermeasures
Attacker downloads modified control logic and manipulates I/O image to drive a process variable past safe limits while suppressing the corresponding BPCS interlock/alarm.	T0864/T0819 -> T0858 Change Operating Mode -> T0843 Program Download / T0835 Manipulate I/O Image -> T0838/T0878 Alarm Suppression -> T0831 Manipulation of Control (TID-406, TID-407, TID-408)	Overpressure/overtemperature or runaway drive with operator blinded to the condition; demand placed on SIF with a defeated IPL.	Major	Yes	Keep SIS in its own 62443 security zone independent of the 5580 (TR84-SECZONE/INDEP); keyswitch in RUN; CIP Security auth; alarm-integrity monitoring; integrate cyber into LOPA (TR84-CRA).
Malicious/rollback firmware flashed via ControlFLASH/AutoFlash or SD auto-load disables or subverts control and any shared protective logic.	T0800 Activate Firmware Update Mode / T0847 Removable Media -> T0857 System Firmware / T0839 Module Firmware (TID-217, TID-216, TID-213, TID-111)	Loss of control and potential loss of protection; controller non-responsive or executing attacker logic.	Major	Yes	Signed anti-rollback firmware, lock/remove SD, keyswitch RUN blocks flashing, authorize updates via MoC (TR84-MOC), verify safety function post-change (TR84-VERIFY).
Rogue master spoofs/replays produce-consume interlock tags between controllers, corrupting a cross-controller safety interlock.	T0848 Rogue Master -> T0856 Spoof Reporting Message -> T0831 Manipulation of Control (TID-407, TID-406, TID-408)	False 'safe' interlock state accepted; hazardous action permitted while operators see normal telemetry.	Serious	Yes	CIP Security message authentication + nonces/timestamps (MID-034/036/037); dedicated interlock conduit; consequence/severity review (TR84-CONSEQ).
CIP/EtherNet/IP DoS (stack exhaustion, duplicate-IP conflict, thermal DoS) inhibits controller response during a process upset.	T0866/T0819 -> T0814 Denial of Service / T0816 Device Restart -> T0813 Denial of Control (TID-405, TID-202)	Loss of availability/control at a critical moment; SIF must act as last line of defense.	Serious	Yes	Network segmentation, DoS protection (SR 7.1/CR 7.1), independent SIS, watchdog and deterministic safe-state outputs (CR 3.6).

8. Risk Register

ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements
R1	Unauthenticated CIP/EtherNet/IP management allows program download, mode change and I/O manipulation by any host that reaches the controller.	TID-406, TID-407	T0843, T0858, T0835, T0831	H	H	Critical	Enable CIP Security (auth + encryption), enforce FactoryTalk Security, keyswitch in RUN/key removed, segment into deny-by-default control zone.	CR 1.2, CR 2.1, CR 3.1, SR 1.2, SR 5.2

ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements
R2	Malicious or rolled-back firmware installed via ControlFLASH/AutoFlash/SD auto-load provides persistence and can disable control/protection.	TID-213, TID-216, TID-217, TID-111	T0857, T0800, T0839, T0847	M	H	High	Signed, anti-rollback firmware; gate flashing with keyswitch/authorization; lock/remove SD; apply MoC and post-change safety verification.	EDR 3.10, CR 3.4, EDR 3.14, SR 3.4
R3	EtherNet/IP/CIP stack exploitation or resource exhaustion crashes the controller (DoS/loss of control).	TID-202, TID-405	T0814, T0816, T0866, T0813	M	H	High	Patch firmware promptly; harden parsers/request limits; network segmentation, rate limiting and IDS; monitor duplicate-IP conflict.	CR 3.5, CR 7.1, SR 7.1, SR 6.2
R4	Unauthenticated HTTP web pages, PTP and BOOTP disclose device/process information aiding targeted attacks.	TID-310, TID-408, TID-226	T0846, T0888, T0882	H	M	High	Disable controller web pages and 4-char display via CIP hardening; least functionality; restrict access from untrusted networks.	CR 7.7, SR 1.13, SR 7.7
R5	Cleartext CIP/produce-consume with no replay protection enables rogue-master spoofing of interlock/telemetry data.	TID-407, TID-408, TID-406	T0848, T0856, T0830	M	H	High	CIP Security message authentication, nonces and timestamps; dedicated interlock conduits; alarm-integrity monitoring.	CR 3.1, SR 3.1, CR 3.8
R6	Compromised engineering workstation / infected .ACD project pushes malicious logic or firmware (controller over-trusts offboard IDE).	TID-303, TID-301	T0864, T0873, T0889	M	H	High	Harden/allowlist EWS, transient-asset controls, code signing for programs, on-device authorization independent of WS.	CR 2.1, SR 3.4, SD-4
R7	Physical/local access via USB, SD or latent debug port enables firmware/memory extraction or injection.	TID-115, TID-111, TID-119	T0847, T0862	L	M	Medium	Physically secure chassis/SD/USB, disable SD auto-load, disable/protect debug ports, engage readout protection.	EDR 2.13, EDR 3.11, CR 2.13
R8	On-device fault/audit log lacks tamper protection and off-device export, hindering detection and forensics.	TID-225, TID-226	T0872	M	M	Medium	Enable security auditing, protect audit info, export logs to SIEM/historian.	CR 3.9, CR 6.1, SR 6.2
R9	Disable Keying / Compatible Module keying permits rogue or mismatched modules on the chassis/network.	TID-406	T0839, T0848	M	M	Medium	Use Exact Match electronic keying; component/peripheral authentication; inventory validation.	CR 7.8, CR 3.4, SR 7.8

9. Threat Model Diagram



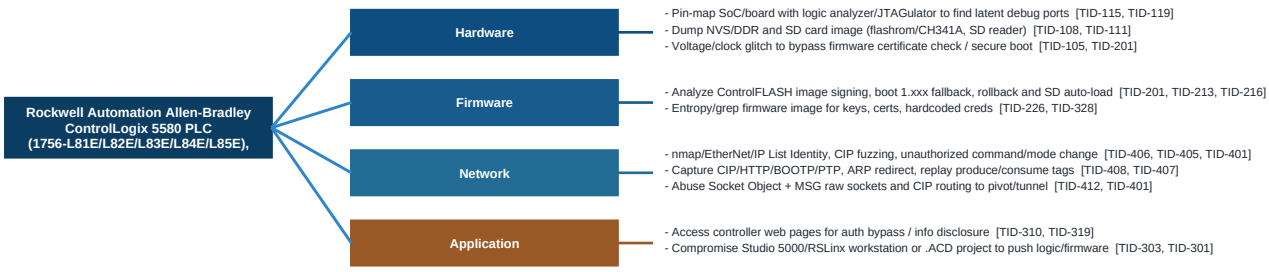
10. ATT&CK for ICS Kill Chain



11. SANS ICS Cyber Kill Chain



12. Attack Mind Map



Assumptions

- The manual excerpt (1756-UM543E-EN-P, Dec 2016) documents no on-controller user credentials, transport cryptography, or CVEs; on-device authentication/authorization is assumed to be delegated to offboard FactoryTalk Security unless CIP Security is separately deployed.
- Legacy CIP/EtherNet/IP as documented lacks message authentication and encryption; CIP Security (DTLS/TLS) is assumed available on supported firmware but not confirmed in the provided excerpt.
- A hardware debug interface (JTAG/UART) is assumed present on the Logix5585 SoC/board for production even though not documented in the manual.
- Firmware signing/certificate validation is inferred from fault codes (Signature Mismatch #0005, Corrupt Certificate/Image Received); depth of validation and root-of-trust immutability are not documented and assumed

uncertain.

- The controller may share a 1756 chassis/backplane and conduits with a Safety Partner (1756-L8xES/Logix5585 'SAFETY ON') and BPCS interlocks, making ISA-TR84.00.09 applicable to the deployment.
- Specific historical Rockwell CIP/EtherNet/IP CVEs are not enumerated in the excerpt; TID-202 exposure is based on the class of documented network stack functionality.
- Items marked with a trailing * (e.g., T0835*) are analyst-added best-practice entries beyond the supplied reference list.